

Cybersecurity Daily Newsletter

Vol. 004 | 2026-08-31 09:00 WIB

Top 5 Highlights

- Anthropic warns infostealer malware is hijacking Claude sessions to drain usage
- Chrome Web Store extensions caught stealing crypto, browser data
- [+24h Old] Week in review: Compromised Zimbra servers, previously patched Citrix NetScaler flaw exploited
- [+24h Old] TerminalFix Uses Fake Cloudflare CAPTCHAs to Deploy Reverse-Tunnel Backdoor
- [+24h Old] CyberDanube Security Research 20260611-0 | Multiple Denial of Service Vulnerabilities in Dahua IPC/SD/NVR/XVR/EVS/VTO/VTH/ASI/TPC Camera Series

Threat Intelligence (10)

01. Anthropic warns infostealer malware is hijacking Claude sessions to drain usage

Anthropic is warning some Claude users that infostealer malware on their PCs has stolen active Claude login sessions, allowing attackers to access accounts and consume their usage. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/artificial-intelligence/anthropic-warns-infostealer-malware-is-hijacking-claude-sessions-to-drain-usage/>

02. Chrome Web Store extensions caught stealing crypto, browser data

Multiple extensions for Google Chrome and Microsoft Edge delivered a malware framework that deployed modules to steal cryptocurrency, sensitive data, and browser history, as well as inject ClickFix lures. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/chrome-web-store-extensions-caught-stealing-crypto-browser-data/>

03. [+24h Old] TerminalFix Uses Fake Cloudflare CAPTCHAs to Deploy Reverse-Tunnel Backdoor

Microsoft has disclosed details of a new ClickFix variant, dubbed TerminalFix, that aims to trick users into running a malicious command in Windows Terminal or PowerShell. "While traditional ClickFix campaigns direct victims to the Windows Run dialog, TerminalFix campaigns apply the same technique but direct users to Windows Terminal or PowerShell instead,..."

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/08/terminalfix-uses-fake-cloudflare.html>

04. [+48h Old] TerminalFix campaign deploys a reverse tunnel through multistage intrusion

Microsoft Threat Intelligence provides analysis of a ClickFix campaign that uses fake CAPTCHA prompts, DLL sideloading, and a reverse tunnel, with detections and hunting guidance. The post TerminalFix campaign deploys a reverse tunnel through multistage intrusion appeared first on Microsoft Security Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/08/28/terminalfix-campaign-deploys-reverse-tunnel-through-multistage-intrusion/>

05. [+48h Old] SVG attachments used in widespread phishing campaign

The attackers employed a broad, non-targeted approach, sending messages in waves and largely avoiding weekends.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/brief/svg-attachments-used-in-widespread-phishing-campaign>

06. [+48h Old] 19 Chrome and Edge Extensions Found With Wallet-Stealing and Crypto-Draining Code

Cybersecurity researchers have discovered a cluster of 18 Google Chrome and one Microsoft Edge extensions that were published over the last six months and harbored wallet secret stealing and cryptocurrency draining capabilities. The extensions, per Socket security researcher Karlo Zanki, share similarities in code and tradecraft, with evidence indicating th...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/08/19-chrome-and-edge-extensions-found.html>

07. [+48h Old] Fake Voicemail SVG Attachments Fuel Large-Scale Phishing Campaign

A large-scale phishing campaign used fake voicemail SVG attachments to bypass email defenses, targeting 5527 organizations with over 26,000 malicious messages

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/fake-voicemail-svg-files-bypass/>

08. [+48h Old] APT28-Linked HOOKEDGE Backdoor Targets European Government and Diplomatic Organizations

Cybersecurity researchers have flagged a fresh set of campaigns targeting government and diplomatic organizations in Romania, Spain, and Türkiye between late September 2025 and early April 2026. These campaigns, per Recorded Future Insikt Group, have led

to the deployment of a previously undocumented backdoor dubbed HOOKEDGE, a lightweight Windows batch scr...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/08/apt28-linked-hookedge-backdoor-targets.html>

09. [+48h Old] Some Malicious PE Stats, (Thu, Aug 27th)

During my last FOR610 session, a student asked me if I had some statistics in mind about the compilers used to generate malicious PE files? A couple of months ago, I shared some stats about the trend in 64bits VS. 32bits malware[1]. Can we go a bit further? I (vibe-)coded a Python script based on the pefile library[2] to extract some info from the PE header...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33292>

10. [+48h Old] Australian cops cuff alleged TeamPCP masterminds

Alleged crew behind the Shai-Hulud worm and other supply chain attacks nabbed with help from the FBI

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.theregister.com/security/2026/08/28/australian-cops-cuff-alleged-teampcp-master-minds/5293157>

Latest Vulnerabilities (10)

01. [+24h Old] Week in review: Compromised Zimbra servers, previously patched Citrix NetScaler flaw exploited

Here's an overview of some of last week's most interesting news, articles, interviews and videos: Unpatched Zimbra servers are falling to CVE-2026-73570 attacks At least 274 internet-facing Zimbra instances have been compromised by unknown attackers via CVE-2026-73570, the Shadowserver Foundation shared on Monday. AI supply chain risk is showing up in devel...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/08/30/week-in-review-compromised-zimbra-servers-previously-patched-citrix-netscaler-flaw-exploited/>

02. [+24h Old] CyberDanube Security Research 20260611-0 | Multiple Denial of Service Vulnerabilities in Dahua IPC/SD/NVR/XVR/EVS/VTO/VTH/ASI/TPC Camera Series

Posted by Thomas Weber | CyberDanube via Fulldisclosure on Aug 29 CyberDanube Security Research 20260611-0 ----- title| Multiple Denial of Service product| Dahua DH-IPC-HFW Series vulnerable version| fixed version| Versions build including and after 2026-03-26. CVE number| CVE-2026-29...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/120>

03. [+24h Old] Multiple Integer Overflows in U-Boot Filesystem Parsing (CVE-2025-70290 through CVE-2025-70293)

Posted by t.preissl via Fulldisclosure on Aug 29 -----BEGIN SECURITY ADVISORY----- Title: Multiple Integer Overflows in U-Boot Filesystem Handling Author: Timo Preißl Date: 2026-02-11 CVEs: CVE-2025-70290, CVE-2025-70291, CVE-2025-70292, CVE-2025-70293 Affected: Denx U-Boot Fixed in: v2026.04-rc1 (commit adccdb2) == Overview == Multiple integer overflow vul...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/119>

04. [+24h Old] JSON Deserialiser Unconstrained Resource Consumption Proof of Concept

Posted by Daniel Owens via Fulldisclosure on Aug 29 On 26 October 2025 we published "Struts2 and Related Framework Array/Collection DoS", which was followed up on 07 March 2026 by "JSON Deserialiser Unconstrained Resource Consumption Quick Overview". Today we are publishing a proof of concept that we have been using for more than 15 years against Struts2, N...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/117>

05. [+24h Old] Dovecot Security Advisory 3/2026

Posted by Aki Tuomi on Aug 29 Hi! We're sharing our latest advisory with you and like to thank everyone who contributed in finding and solving those vulnerabilities. This advisory will also be published at <https://documentation.open-xchange.com/dovecot/security/advisories/html/2026/oxdc-adv-2026-0003.html> --- Classification: TLP:GREEN Internal reference: DO...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/116>

06. [+24h Old] Five Critical WordPress Plugin and Theme Flaws Enable Site Takeover or RCE

Multiple critical security flaws have been disclosed in WordPress plugins and themes, including WPMU DEV Dashboard, Avada, TranslatePress, Pods, and GiveWP, that could lead to authentication bypass, account takeover, and arbitrary code execution. The vulnerabilities, according to Wordfence and Patchstack, are listed below - CVE-2026-76581 (CVSS score: 9.8)...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/08/five-critical-wordpress-plugin-and.html>

07. [+48h Old] ServiceNow patches three maximum severity flaws that could put enterprise data at risk

Code injection and SQL injection attacks have been around for decades, and they are still tried-and-true ways for attackers to compromise systems. ServiceNow's latest trio of maximum severity flaws shows that even AI-era platforms remain vulnerable to these techniques: The software provider has released patches for three bugs in its ServiceNow AI Platform t...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4215430/servicenow-patches-three-maximum-severity-flaws-that-could-put-enterprise-data-at-risk.html>

08. [+48h Old] Aurora ransomware actors leverage AI tool for exploitation campaigns

The Aurora ransomware group utilized Cursor Agent for post-compromise activities, providing it with credentials or existing access to victim networks.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/aurora-ransomware-actors-leverage-ai-tool-for-exploitation-campaigns>

09. [+48h Old] Critical vulnerability in GiveWP plugin allows remote code execution

The vulnerability, present in GiveWP versions up to 4.16.7.1, is exploitable by chaining three issues: an unsafe PHP data unserialization helper, a donation processing flow that stores attacker-controlled serialized objects, and a gadget chain within bundled libraries that enables arbitrary system command execution.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/critical-vulnerability-in-givewp-plugin-allows-remote-code-execution>

10. [+48h Old] CISA adds ownCloud, Linux Kernel, and JFrog Artifactory flaws to exploited vulnerabilities list

The newly cataloged vulnerabilities include CVE-2023-49105, an improper authentication flaw in ownCloud Server affecting versions 10.6.0 through 10.13.0, which allows unauthenticated attackers to access or modify user files.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/cisa-adds-owncloud-linux-kernel-and-jfrog-artifactory-flaws-to-exploited-vulnerabilities-list>

Data Breach & Cybercrime (10)

01. [+24h Old] Hasbro Data Breach Exposed Employee Personal Information

A cyberattack caused disruptions at the toy and game giant earlier this year and the company is now disclosing a data breach. The post Hasbro Data Breach Exposed Employee Personal Information appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/hasbro-data-breach-exposed-employee-personal-information/>

02. [+48h Old] McKesson discloses breach after ShinyHunters claims patient data theft

Healthcare and pharmaceutical distribution giant McKesson has disclosed a cybersecurity incident involving unauthorized access to third-party applications and data theft, with the ShinyHunters extortion group claiming it stole 284 million patient data records. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/mckesson-discloses-breach-after-shinyhunters-claims-patient-data-theft/>

03. [+48h Old] Former DIA IT specialist pleads guilty to attempting to leak classified information

A former Defense Intelligence Agency IT specialist has pleaded guilty to attempting to pass secret and top-secret information to foreign spies following a successful FBI sting operation.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/former-dia-it-specialist-pleads-guilty-to-attempting-to-leak-classified-information>

04. [+48h Old] Berlin Refuses to Pay Hackers Who Stole Data From the City's State Network

Berlin's state government has confirmed that it is the target of an extortion attempt following the August compromise of the city's state administrative network, and said it will not meet the extortionists' demands. The same statement disclosed that forensic work had found further data outflows in the portfolio of the Senate Department for Mobility, Transpo...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/08/berlin-refuses-to-pay-hackers-who-stole.html>

05. [+48h Old] The Good, the Bad and the Ugly in Cybersecurity - Week 35

Authorities disrupt global cybercrime rings, attackers abuse DocuSign in NovaCookies phishing, and Spark RAT targets Cambodia with vulnerable drivers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-35-8/>

06. [+48h Old] In Other News: Log4j RCE Scare, Minimus Shutdown, Iranian Hacker Sanctions

Noteworthy stories that might have slipped under the radar: Manchester Airports Group cyberattack, Carhartt breach data was partly fake, U.S. Bank responds to ransomware gang's claims. The post In Other News: Log4j RCE Scare, Minimus Shutdown, Iranian Hacker Sanctions appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/in-other-news-log4j-rce-scare-minimus-shutdown-iranian-hacker-sanctions/>

07. [+48h Old] US government snitch-finder pleads guilty to leaking state secrets to foreign spies

The IT specialist began contacting a foreign government within days of being assigned to the DIA's Insider Threat Division

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/08/28/us-government-snitch-finder-pleads-guilty-to-leaking-state-secrets-to-foreign-spies/5293248>

08. [+48h Old] ATF Confirms Cyber Incident After Ransomware Group Claims Attack

The Bureau of Alcohol, Tobacco, Firearms and Explosives has described it as a 'major incident' and it's conducting an investigation with the DOJ. The post ATF Confirms Cyber Incident After Ransomware Group Claims Attack appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/atf-confirms-cyber-incident-after-ransomware-group-claims-attack/>

09. [+48h Old] Toy-making giant Hasbro disclose data breach affecting employees

Hasbro, one of the world's largest toy and game companies, has disclosed that attackers have accessed the personal and financial information of an undisclosed number of employees. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/toy-making-giant-hasbro-disclose-data-breach-affecting-employees/>

10. [+48h Old] The first 24 hours of an AI agent security incident

Most of what I read on AI agent security follows the same shape: a taxonomy of risks, a list of governance principles and a call to “adopt responsible AI practices.” That’s useful for a board deck. It’s nearly useless at 2 a.m. when an autonomous agent with live credentials has just done something nobody authorized, and someone is asking me what happens next...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.csoonline.com/article/4214961/the-first-24-hours-of-an-ai-agent-security-incident.html>